

服务攻防-端口协议&桌面应用&QQ&WPS 等 RCE&hydra 口令猜解&未授权
检测



#知识点:

- 1、数据库-Redis-未授权 RCE&CVE
- 2、数据库-Couchdb-未授权 RCE&CVE
- 3、数据库-H2database-未授权 RCE&CVE

-
- 1、中间件-IIS-短文件&解析&蓝屏等
 - 2、中间件-Nginx-文件解析&命令执行等
 - 3、中间件-Apache-RCE&目录遍历&文件解析等
 - 4、中间件-Tomcat-弱口令&文件上传&文件包含等

-
- 1、中间件-Jetty-CVE&信息泄漏
 - 2、中间件-Jenkins-CVE&RCE 执行
 - 3、中间件-Weblogic-CVE&反序列化&RCE
 - 4、应用 WPS-HW2023-RCE&复现&上线 CS

-
- 1、PHP-框架安全-Thinkphp&Laravel
 - 2、J2EE-框架安全-SpringBoot&Struts2

-
- 1、J2EE-组件安全-Solr-全文搜索
 - 2、J2EE-组件安全-Shiro-身份验证
 - 3、J2EE-组件安全-Log4J-日志记录

-
- 1、J2EE-组件 Jackson-本地 demo&CVE
 - 2、J2EE-组件 FastJson-本地 demo&CVE
 - 3、J2EE-组件 XStream-本地 demo&CVE

-
- 1、端口协议-弱口令&未授权&攻击方式等
 - 2、桌面应用-社交类&文档类&工具类等

#章节点:

- 1、目标判断-端口扫描&组合判断&信息来源
- 2、安全问题-配置不当&CVE 漏洞&弱口令爆破
- 3、复现对象-数据库&中间件&开发框架&应用协议
- 4、HW 复现-近几年新洞-除上述外的对象各种应用

#常见语言开发框架:

PHP: Thinkphp Laravel YII CodeIgniter CakePHP Zend 等

JAVA: Spring MyBatis Hibernate Struts2 Springboot 等

Python: Django Flask Fastapi Django Rest Framework Django Channels 等



服务攻防-小迪安全



Presented with xmind

端口号	端口说明	攻击方向
21/22/69	ftp/tftp文件传输协议	爆破\嗅探\溢出\后门
22	ssh远程连接	爆破OpenSSH;28个退格
23	telnet远程连接	爆破\嗅探
25	smtp邮件服务	邮件伪造
53	DNS域名系统	DNS区域传输\DNS劫持\DNS缓存投毒\DNS欺骗\利用DNS隧道技术刺透防火墙
67/68	dhcp	劫持\欺骗
110	pop3	爆破
139	samba	爆破\未授权访问\远程代码执行
143	imap	爆破
161	snmp	爆破
389	ldap	注入攻击\未授权访问
512/513/514	linux	直接使用rlogin
873	rsync	未授权访问
1080	socket爆破	进行内网渗透
1352	lotus爆破	弱口令\信息泄漏;源代码
1433	mssql爆破	使用系统用户登录\注入攻击
1521	oracle爆破	TNS\注入攻击
2049	nfs	配置不当
2181	zookeeper	未授权访问
3306	mysql	爆破\拒绝服务\注入
3389	rdp	爆破\Shift后门
4848	glassfish	爆破;控制台弱口令\认证绕过
5000	sybase/DB2	爆破\注入
5432	postgresql	缓冲区溢出\注入攻击\爆破;弱口令
5632	pcanywhere	拒绝服务\代码执行
5900	vnc爆破	弱口令\认证绕过
6379	redis	未授权访问\爆破;弱口令

远程连接服务端口

端口号	端口说明	攻击方向
22	SSH远程连接	爆破、SSH隧道及内网代理转发、文件传输
23	Telnet远程连接	爆破、嗅探、弱口令
3389	Rdp远程桌面连接	Shift 后门（需要 Windows Server 2003 以下的系统）、爆破
5900	VNC	弱口令;爆破
5632	PyAnywhere服务	抓密码、代码执行

文件共享服务端口

端口号	端口说明	攻击方向
21/22/69	Ftp/Tftp文件传输协议	允许匿名的上传、下载、爆破和嗅探操作
2049	Nfs服务	配置不当
139	Samba	爆破、未授权访问、远程代码执行
389	Ldap目录访问协议	注入、允许匿名访问、弱口令

Web应用服务端口

端口号	端口说明	攻击方向
80/443/8080	常见的Web服务端口	Web攻击、爆破、对应服务器版本漏洞
7001/7002	WebLogic 控制台	Java 反序列化、弱口令
8080/8089	Jboss/Resin/Jetty/Jenkins	反序列化、控制台弱口令
9090	WebSpere 控制台	Java 反序列化、弱口令
4848	GlassFish 控制台	弱口令
1352	Lotus domino 邮件服务	弱口令、信息泄露、爆破
10000	Webmin-Web 控制面板	弱口令

数据库服务端口

端口号	端口说明	攻击方向
3306	MySQL	注入、提权、爆破
1433	MSSQL	注入、提权、SA 弱口令、爆破
1521	Oracle TNS	爆破、注入、反弹 Shell
5432	PostgreSQL	爆破、注入、弱口令
27017	MongoDB	爆破、未授权访问
6379	Redis	未授权访问、弱口令爆破
5000	SyBase/DB2	爆破、注入

邮件服务端口

端口号	端口说明	攻击方向
25	SMTP 邮件服务	邮件伪造
110	POP3 协议	爆破、嗅探
143	IMAP 协议	爆破

网络常见协议端口

端口号	端口说明	攻击方向
53	DNS 域名系统	允许区域传送、DNS劫持、缓存投毒、欺骗
67/68	DHCP 服务	劫持、欺骗
161	SNMP 协议	爆破、搜集目标内网信息

特殊服务端口		
端口号	端口说明	攻击方向
2181	Zookeeper 服务	未授权访问
8069	Zabbix 服务	远程执行、SQL 注入
9200/9300	Elasticsearch 服务	远程执行
11211	Memcache 服务	未授权访问
512/513/514	Linux Rexec 服务	爆破、Rlogin 登录
873	Rsync 服务	匿名访问、文件上传
3690	Svn 服务	Svn泄露、未授权访问
50000	SAP Management Console	远程执行

演示案例：

- 端口协议-口令爆破&未授权
 - 桌面应用-QQ&WPS&Clash
-
-

#端口协议-口令爆破&未授权

参考: https://mp.weixin.qq.com/s/xp_LOUmGImrRmkPrDqxKjw

-弱口令爆破

<https://github.com/vanhauser-thc/thc-hydra>

hydra 是一个自动化的爆破工具,暴力破解弱密码,

是一个支持众多协议的爆破工具,已经集成到 KaliLinux 中,直接在终端打开即可

-s PORT 可通过这个参数指定非默认端口。

-l LOGIN 指定破解的用户,对特定用户破解。

-L FILE 指定用户名字典。

-p PASS 小写,指定密码破解,少用,一般是采用密码字典。

-P FILE 大写,指定密码字典。

-e ns 可选选项, n: 空密码试探, s: 使用指定用户和密码试探。

-C FILE 使用冒号分割格式,例如“登录名:密码”来代替-L/-P 参数。

-M FILE 指定目标列表文件一行一条。

-o FILE 指定结果输出文件。

-f 在使用-M 参数以后,找到第一对登录名或者密码的时候中止破解。

-t TASKS 同时运行的线程数,默认为 16。

-w TIME 设置最大超时的时间,单位秒,默认是 30s。

-v / -V 显示详细过程。

server 目标 ip

service 指定服务名,支持的服务和协议: telnet ftp pop3[-ntlm] imap[-ntlm] smb smbnt http-{head|get} http-{get|post}-form http-proxy cisco cisco-enable vnc ldap2 ldap3 mssql mysql oracle-listener postgres nntp socks5 rexec rlogin pcnfs snmp rsh cvs svn icq sapr3 ssh smtp-auth[-ntlm] pcanywhere teamspeak sip vmauthd firebird ncp afp 等等。

例子:

FTP: 文件传输协议

RDP: Windows 远程桌面协议

SSH: Linux 安全外壳协议

hydra -L test -P 10top1K.txt 47.110.53.159 ftp -V

hydra -l root -P 10top1K.txt 47.110.53.159 ssh -V

hydra -l administrator -P 10top1K.txt 47.110.53.159 rdp -V

-未授权案例:

<https://github.com/xk11z/unauthorized>

rsync 是 Linux 下一款数据备份工具,支持通过 rsync 协议、ssh 协议进行远程文件传输。其中 rsync 协议默认监听 873 端口,如果目标开启了 rsync 服务,并且没有配

涉及资源：

补充：[涉及录像课件资源软件包资料等下载地址](#)
